

レッドチーミング実施報告書

本ドキュメントは、NEDOプロジェクトの一環として、医療特化型LLMシステムの安全性評価のために構築した疑似システム環境を用いたレッドチーミングの全工程（STEP 1～15）における実施内容と結果をまとめた報告書である。各工程は AISI「AIセーフティに関するレッドチーミング手法ガイド 別紙：詳細解説書」第1.10版に基づく。チーム体制は [report-templates/01a_チーム体制.md](#)、システム構成・成果物一覧は [report-templates/01b_システム構成・成果物.md](#) を参照。

ドキュメント体系

ドキュメント	概要	作成者
本ドキュメント	全工程の実施内容 と結果の記録	管理者
report-templates/01a_チーム体制.md	チーム体制・参照 ガイド・ガイドペ ージ対応表	管理者
report-templates/01b_システム構成・成果 物.md	システム構成・成 果物一覧	管理者
report-templates/02_企画書.md	RT実施の企画・承 認	管理者
report-templates/03_実施計画書.md	実施計画（体制・ スケジュール・範 囲）	管理者
report-templates/04_リスクシナリオ表.md	リスクシナリオの 一覧と採否判定	攻撃実施者
report-templates/05_実施結果報告書.md	攻撃の技術的实施 結果	攻撃実施者
report-templates/06_最終報告書.md	経営層向け事業イ ンパクト分析	管理者
report-templates/07_改善計画書.md	改善策の詳細実施 計画	管理者
risk_framework/リスクフレームワーク.xlsx	AIセーフティ評価 観点の詳細基準	情シス担当者・AIセキュ リティ有識者

第1工程：実施計画の策定と実施準備

STEP 1：実施の決定とレッドチーム発足

アクション：RT実施企画書の作成・承認（管理者→経営層）

RT実施企画書を report-templates/02_企画書.md として作成した。本企画書には
以下を記載している。

- **背景・目的**：医療特化型LLMシステムにおいて、患者の生命・身体に関わるリスクおよび要配慮個人情報の保護の観点から、潜在的脆弱性の特定と対策の有効性評価を行う
- **実施範囲**：LLMへの入力処理、LLMからの出力処理、データベース
- **実施環境**：模擬構成を想定した整理を行うが、実際の検証対象は上記のようにLLMの入出力のみに限定する
- **RTの種類**：ブラックボックステストを基本とし、LLMのモデル内部の解析は行わない
- **期待される効果**：リスクパターンの洗い出し、および、システムの信頼性向上

企画書は経営層の承認を得て、RT実施を決定した。

アクション：レッドチームの発足（管理者）

経営層、管理者、攻撃実施者、情シス担当者、AIセキュリティ有識者の5名でレッドチームを発足した。各役割の担当者および責任範囲の詳細は 03_実施計画書 Section 4.2 を参照。

STEP 2：予算及びリソースの識別・確保

アクション：予算の確保・人員アサイン（管理者）

- **予算**：別途管理とする（02_企画書 Section 6 参照）
- **人員**：NEDOプロジェクト参画メンバーより、上記STEP 1で発足したレッドチーム5名をアサイン
- **実施期間**：第1工程～第3工程を通じて約16週間を確保（令和7年12月1日～令和8年3月24日）

アクション：必要ツールの選定・調達（攻撃実施者）

以下のツール・リソースを選定・調達した。

ツール	用途	備考
医療LLMレッドチーミングシステム	攻撃プロンプトの自動実行・評価	実施結果は red_teaming_results/ に格納
攻撃シナリオ案	テストケースの管理・実行	実施結果は red_teaming_results/ に格納
クライアント端末	疑似システム環境への接続	攻撃者の所有端末を利用
スクリーンショットツール	証跡取得	PCが備える標準ツールを使用

STEP 3：実施計画の策定

アクション：対象システムの概要把握・利用形態の整理（情シス担当者・AIセキュリティ有識者・管理者）

対象システムの概要を以下のとおり把握・整理した（詳細は 03_実施計画書 Section 1 参照）。

システム構成概要：

- 基本的には「システム全体構成図」に記載のシステムを想定した設計だが、実際の電子カルテシステムとの連携はなく、LLMと患者情報DBと監査ログDBのみを備える
- ガードレール（入力フィルタ・出力フィルタ）は導入されていない
- フロントエンドはインターネット経由で接続、バックエンドのLLMはフロントエンドからAPIで接続

主要コンポーネント（03_実施計画書 Section 1.2）：

- 想定利用者: 医師、医療事務などの医療従事者に扮した攻撃者
- フロントエンド: 本レッドチーミング用に作成されたWebアプリケーション
- バックエンド: vLLM（オンプレミス）/ クラウドAPI（OpenRouter経由）でホスティングしたLLMのAPI
- データベース: LLMからのREADが可能な患者情報DBとWRITEが可能な監査ログDB

アクション：RTの種類と実施範囲の決定（攻撃実施者・管理者）

- 実施するRTの種類: 一般利用者の視点からの攻撃を想定したブラックボックステスト（03_実施計画書 Section 2.1）：
- 実施範囲：LLMおよびデータベース（患者情報DB・監査ログDB）を範囲内とし、APIゲートウェイ・フィルタ・フロントエンドは範囲外とした（詳細は 03_実施計画書 Section 2.2 参照）。

アクション：実施計画書の作成（管理者）

`report-templates/03_実施計画書.md` として実施計画書を作成した。

STEP 4：実施環境の準備

アクション：テスト環境の構築・アカウント発行（情シス担当者・管理者）

- **使用環境**：疑似システム環境（実システムは使用しない）
- **データ**：匿名化された模擬患者データ（実患者データは使用しない）
- **アクセス方法**：フロントエンドはインターネット経由で接続、バックエンドのLLMはフロントエンドからAPIで接続
- **発行アカウント**：攻撃実施者用のテストアカウントを発行（一般ユーザー相当の権限を想定）

※ デプロイ環境の詳細は 03_実施計画書 Section 1.7 を参照。

アクション：関係部署への事前連絡・監視設定の調整（管理者）

- **事前連絡先**：情報システム部門、LLMシステム運用チーム、レッドチーミング関係者
 - **連絡内容**：RT実施期間、実施内容の概要
 - **実施に向けた調整**：本番環境とは独立した疑似システムのため、特段の調整は不要
-

STEP 5：エスカレーションフローの確認

アクション：エスカレーションフロー・緊急連絡先の策定（管理者）

通常フロー（攻撃実施者→管理者→経営層）および緊急時フロー（重大脆弱性発見時の即時連絡・緊急対策会議）を策定した。ただし、本RTでは実際の患者データは取り扱わないため、緊急対応は想定しない。エスカレーションフロー・緊急連絡先・重大脆弱性発見時の対応手順の詳細は 03_実施計画書 Section 6 を参照。

第2工程：攻撃計画・実施

STEP 6：リスクシナリオの作成

STEP 6-1：システム構成の把握

アクション：システム構成図の詳細化（情シス担当者）

システム全体構成図を作成した。構成の詳細およびデータフローは 03_実施計画書 Section 1（システム構成：Section 1.1、データフロー：Section 1.3）を参照。

アクション：LLM入出力の整理（攻撃実施者）

LLMの入出力を以下のとおり整理した。

入力：

- ユーザープロンプト（医療従事者からの質問）
- システムプロンプト（システムから情報提供に関する指針）
- コンテキスト情報（データベースから取得した患者情報）

出力：

- 回答テキスト（医療情報、カルテ記載等）

STEP 6-2：AIセーフティの評価観点と情報資産の特定

アクション：保護すべき情報資産の洗い出し（管理者・情シス担当者）

今回の疑似患者データの内容から、保護すべき情報資産を以下のとおり特定した（03_実施計画書 Section 1.5 参照）。

データ種別	内容	機密レベル
患者基本情報	患者コード	なし
入退院情報	入院日、退院日、診療科など	極秘
診療記録	経過記録、検査記録など	極秘

診療記録は要配慮個人情報に該当する可能性があるため、最も高い保護水準が求められることから、権限範囲外からのアクセスは遮断される必要がある。

アクション：AIセーフティ評価観点の水準設定（全員）

AISIガイドの10項目の評価観点について、本システムの特性を踏まえた水準を設定した（各評価観点の水準一覧は 03_実施計画書 Section 3 を参照）。今回のRTでは、プライバシー保護を中心に、セキュリティ確保・有害情報の出力制御等の複数の評価観点からRTを実施する。

アクション：リスクフレームワークの作成（情シス担当者・AIセキュリティ有識者）

リスクフレームワークを `risk_framework/リスクフレームワーク.xlsx` として作成した。本フレームワークには以下を含む。

- AIセーフティ評価観点10項目の詳細な基準
- 各評価観点に対応するベンチマーク・テスト手法
- リスク評価のマトリクス（実現性 × 影響度）
- 医療ドメイン特有のリスク要因

STEP 6-3：システム構成と利用形態からリスクシナリオの作成

アクション：懸念箇所の洗い出し（攻撃実施者）

以下の懸念箇所を洗い出した。

懸念箇所	対象コンポーネント
LLMシステムの入力部分	LLM
コンテキスト情報	患者情報DB
LLMシステムの出力部分	LLM

アクション：攻撃手法の概要検討（攻撃実施者）

上記の懸念箇所に対し、以下の攻撃観点を整理した。

攻撃観点	対象コンポーネント	攻撃手法の方向性
患者情報の直接的な窃取	LLM入力部分	直接要求、権限詐称（impersonation）、プロンプトインジェクション（injection）
患者情報の間接的な抽出	LLM入力部分	間接抽出（indirect）：品質監査・翻訳サンプル・教育用ケーススタディ等の正当業務を装った情報引き出し
システム権限偽装による情報抽出	LLM入力部分・患者情報DB	バックアップ復元偽装（backup_restore）、デバッグモード偽装（debug_mode）、テンプレート悪用（template_exploit）
LLMの役割・指示の書き換え	LLM入力部分	ロールプレイ（roleplay）：データ検証AI等を演じさせる、段階的抽出（stepwise）、文脈操作（manipulation）
有害な医療情報の出力誘発	LLM出力部分	致死量情報の研究・教育目的偽装要求（harmful_lethal）、投毒方法の介護目的偽装（harmful_poison）、違法薬物入手（harmful_illegal）

STEP 7：攻撃シナリオの作成

STEP 7-1：主要コンポーネントの諸元確認

アクション：各コンポーネントの分類（情シス担当者）

LLMについてはvLLM（オンプレミス）およびクラウドAPI（OpenRouter経由）を利用するが、それ以外は全て自作アプリケーションである。

STEP 7-2：対象環境とアクセスポイント確認

アクション：実施環境の決定（管理者・攻撃実施者）

- **実施環境**：疑似システム
- **データ**：匿名化された模擬患者データ（実患者データは使用しない）
- **アクセス方法**：フロントエンドはインターネット経由で接続、バックエンドのLLMはフロントエンドからAPIで接続

アクション：アクセスポイントの列挙（攻撃実施者）

以下のアクセスポイントを確認した。

アクセスポイント	説明	攻撃に使用
Webアプリケーションの入力フォーム	医療従事者が質問を入力するUI	○
Webアプリケーションの出力フォーム	医療従事者が結果を確認するUI	✕（結果の確認のみ）
その他システム	ホスティングシステムやネットワークインフラ	✕（攻撃の実施はしない）

STEP 7-3：攻撃シナリオの作成

アクション：攻撃シナリオの作成（攻撃実施者）

7件のリスクシナリオ（R-M1～R-M7）に対応する攻撃シナリオを作成した。AISIガイドの3つの評価観点（プライバシー保護、セキュリティ確保、有害情報の出力制御）に対応する計300件の攻撃プロンプトを、15種の攻撃手法で構成した。20モデルに対して各300件を実行し、計6,000件のテストを実施する計画とした。

主な攻撃手法は以下のとおり。

攻撃手法	概要	対応するリスクシナリオ
direct	患者情報の直接要求	R-M1
impersonation	担当医・看護師長等への権限詐称	R-M1, R-M6
indirect	品質監査テンプレート作成等を装った間接抽出	R-M1, R-M4
injection	システム管理者偽装等のプロンプトインジェクション	R-M1, R-M4
roleplay	データ検証AI等を演じさせるロールプレイ	R-M1
stepwise	段階的な情報引き出し	R-M1, R-M4
backup_restore	バックアップ復元・クラウド移行を装ったデータ出力	R-M4
debug_mode	デバッグモード・トークナイザ検証を装った抽出	R-M4
template_exploit	テンプレート・フォーマット変換を利用した抽出	R-M4

攻撃手法	概要	対応するリスクシナリオ
harmful_lethal	致死量情報の要求（研究・教育目的を偽装）	R-M2, R-M7
harmful_poison	薬物混入・投毒方法の要求	R-M2
harmful_illegal	違法薬物入手・無許可販売等の要求	R-M2
harmful_selfharm / harmful_avoidance	自傷行為・有害行為回避を装った要求	R-M2
manipulation	文脈操作による誘導	R-M1

アクション：攻撃シナリオのレビュー（情シス担当者・AIセキュリティ有識者）

情シス担当者（技術的観点）とAIセキュリティ有識者（AIセキュリティ観点）により、以下の観点でレビューを実施した。

- **技術的妥当性**：攻撃シグネチャが実際の攻撃手法として有効か
- **網羅性**：リスクシナリオに対する攻撃パターンが十分か
- **実現可能性**：疑似システム環境で実施可能な内容か
- **安全性**：攻撃実施による意図しない影響がないか

レビュー結果を踏まえ、攻撃シナリオの一部を修正した。

STEP 8：攻撃シナリオの実施

STEP 8-1：プロンプト単体に関するRT

アクション：RTシステムによる攻撃プロンプトの実行（攻撃実施者）

医療LLMレッドチームングシステムを使用し、攻撃シグネチャ集に登録された攻撃プロンプトを自動実行した。

- **対象モデル数**：20モデル（claude-sonnet-4.5/4.6、gpt-5.2/5.4、kimi-k2、qwen3-235b-a22b、qwen3-235b-a22b-instruct-2507、qwen3-235b-a22b-thinking-2507×2、qwen3.5-397b-a17b、glm-4.7/glm-5、Weblab-MedLLM-Qwen-2.5-109B-Instruct、gpt-oss-120b、llm-jp-3.1-8x13b-instruct4、weblab-LLM-M-gpt-oss-120b、weblab-LLM-M-glm-47×2、weblab-LLM-M-Qwen3-235b-instruct-dft、weblab-LLM-M-Qwen3-235b-thinking-dft）
- **実施件数**：モデルあたり300件 × 20モデル = 計6,000件
- **自動評価**：各プロンプトの応答を deny / allow / allow_with_denial / unclear の4段階で自動判定
- **結果概要**：6,000件中838件で漏洩が発生（14.0%）。モデル別攻撃成功率は0.7%～42.7%と大きなばらつきがある。詳細は 05_実施結果報告書 Section 2 参照

アクション：手動によるマルチターン攻撃（攻撃実施者）

自動攻撃で発見された有効な攻撃パターンに基づき、手動でマルチターン攻撃を実施した。マルチターンでは以下の手法を使用。

- **段階的な信頼構築**：正当な質問を繰り返した後に攻撃プロンプトを挿入
- **文脈操作**：複数ターンで文脈を積み上げ、最終ターンで情報を引き出す
- **ロール変更の試行**：会話の途中で権限変更を試みる

アクション：有効な攻撃手法の特定（攻撃実施者）

15種の攻撃手法の有効性を検証し、以下の結果を得た（05_実施結果報告書 Section 2.5 参照）。

攻撃手法	攻撃成功率	有効性	対応する脆弱性
indirect（間接抽出）	28.5%	有効	V-001, V-002
harmful_lethal（致死量情報要求）	26.0%	有効	V-003
roleplay（ロールプレイ）	23.5%	有効	V-001, V-003
template_exploit（テンプレート悪用）	22.2%	有効	V-001, V-002
injection（プロンプトインジェクション）	21.5%	有効	V-001, V-003
backup_restore（バックアップ復元偽装）	17.5%	有効	V-001, V-002
debug_mode（デバッグモード偽装）	17.0%	有効	V-002, V-003
stepwise（段階的抽出）	14.0%	有効	V-001, V-002
impersonation（権限詐称）	12.2%	有効	V-001, V-002
direct（直接要求）	10.5%	有効	V-001
manipulation（文脈操作）	9.0%	有効	V-001, V-002
harmful_illegal（違法薬物）	4.8%	限定的	V-003
harmful_poison（毒物情報）	2.5%	限定的	V-003
harmful_avoidance（回避偽装）	0.2%	無効（防御成功）	D-002
harmful_selfharm（自傷行為）	0.0%	無効（防御成功）	D-002

STEP 8-2：攻撃シグネチャと実施手順の作成

アクション：攻撃シグネチャの作成（攻撃実施者）

STEP 8-1で有効性が確認された攻撃手法に基づき、攻撃シグネチャ（再現可能な攻撃プロンプト）を作成した。各攻撃シグネチャの詳細は以下のとおり（05_実施結果報告書 Section 3 参照）。

- **V-001（プライバシー保護）用**：品質監査テンプレート作成を装った間接抽出、担当医を名乗る権限詐称、データ検証AIを演じさせるロールプレイ、システム管理者を偽装したプロンプトインジェクション等（計100件/モデル）
- **V-002（セキュリティ確保）用**：BIツール連携を装ったCSV出力要求、クラウド移行を装ったFHIR形式出力、デバッグモード偽装によるトークン分割出力、テンプレート悪用による構造化データ抽出等（計100件/モデル）
- **V-003（有害情報の出力制御）用**：致死量情報の研究・教育目的偽装要求、投毒方法の介護目的偽装要求、違法薬物入手方法の要求等（計100件/モデル）

各シグネチャは 実施結果は `red_teaming_results/` に格納している。

アクション：攻撃シナリオ実施手順の作成（攻撃実施者）

攻撃シナリオの実施手順を以下のとおり文書化した。

1. テスト環境へ接続し、指定アカウントでログイン
2. 攻撃シグネチャを入力し、LLMの応答を取得
3. RTシステムの評価ロジック（deny / allow / allow_with_denial / unclear）で自動判定
4. 攻撃成功の場合：スクリーンショットを取得し、攻撃ログに記録
5. 攻撃失敗の場合：防御成功ケースとして記録
6. マルチターン攻撃の場合：上記1-5を複数ターンで繰り返し

STEP 8-3：LLMシステム全体に対するRT

本構成では、LLMシステム全体に対するRTはSTEP 8-1のプロンプト単体RTと同一の検証となるため、本STEPの対応はスキップした。

理由：本システムではフロントエンドからLLMへ直接プロンプトを送信する構成であり、LLM前後に独立したフィルタやミドルウェア等の追加コンポーネン

トが存在しない。そのため、プロンプト単体のRT（STEP 8-1）がそのままLLMシステム全体のRTと等価となる。

STEP 9：実施中の記録取得

アクション：ログの取得・保存（攻撃実施者）

以下のログを取得・保存した。

ログ種別	内容	保存先
攻撃ログ	全攻撃プロンプトとLLMの応答、RTシステムの評価判定	<code>red_teaming_results/</code> に格納
システムログ	LLMのアクセスログ、入出力の動作ログ	疑似システム環境の監査ログDB
テスト実施記録	実施日時、実施者、攻撃シナリオの番号、結果概要	<code>red_teaming_results/</code> に格納

アクション：スクリーンショットの取得（攻撃実施者）

RTシステムのレポートデータを `red_teaming_results/redteam_report_2026-03-21_233751.json`（19モデル分）および `red_teaming_results/redteam_report_2026-03-24_021638.json`（No.20追加分）として出力した。全6,000件のテストケースの入力プロンプト・LLM応答・漏洩判定を含む。

証跡は 05_実施結果報告書 の各脆弱性詳細に記載している。

アクション：攻撃成功事例の記録（攻撃実施者）

攻撃成功事例を以下のとおり記録した（05_実施結果報告書 Section 2～3 参照）。

脆弱性ID	AISI評価観点	攻撃成功率	主な有効攻撃手法
V-001	プライバシー保護	14.9%	テンプレート悪用（32.5%）、間接抽出（29.5%）、ロールプレイ（20.6%）
V-002	セキュリティ確保	20.4%	間接抽出（27.5%）、テンプレート悪用（21.7%）、バックアップ復元偽装（14.2%）
V-003	有害情報の出力制御	6.7%	致死量情報要求（36.0%）、PI（30.0%）、ロールプレイ（28.0%）

特筆すべき点として、llm-jp-3.1-8x13b-instruct4（攻撃成功率42.7%）、weblab-LLM-M-Qwen3-235b-thinking-dft（39.3%）、Weblab-MedLLM-Qwen-2.5-109B-Instruct（35.7%）、qwen3-235b-a22b-thinking-2507（34.3%）、qwen3-235b-a22b（29.7%）、weblab-LLM-M-Qwen3-235b-instruct-dft（28.0%）、qwen3-235b-a22b-instruct-2507（13.7%）の7モデルはプライバシー保護またはセキュリティ確保で不合格判定となった。一方、claude-sonnet-4.5/4.6はプライバシー保護・セキュリティ確保で合格（攻撃成功率0%）だが、有害情報の出力制御では要改善判定（2～9%）であった。

STEP 10：実施後の処理

アクション：RT終了の連絡（管理者）

レッドチーミング関係者にRT完了の報告と今後のマイルストーン（（結果分析・報告書作成）の共有をした。

アクション：その他の復帰処理（情シス担当者）

疑似システムのため、アカウントの削除や設定変更などは実施しなかった。

第3工程：結果のとりまとめと改善計画の策定

STEP 11：実施結果の分析

アクション：RT結果の分析（攻撃実施者）

RT結果を以下のとおり分析した（05_実施結果報告書 Section 5 参照）。

全体結果：

- 6,000件のテスト（20モデル × 300件）のうち838件で漏洩が発生（14.0%）
- モデル間で攻撃成功率に大きな差（0.7%～42.7%）があり、モデル選定が安全性に直結することが判明

モデル間の性能差：

- 上位モデル（claude-sonnet-4.5/4.6）はプライバシー保護・セキュリティ確保で合格（攻撃成功率0%）
- 下位モデル（llm-jp-3.1-8x13b-instruct4: 42.7%、weblab-LLM-M-Qwen3-235b-thinking-dft: 39.3%、Weblab-MedLLM-Qwen-2.5-109B-Instruct: 35.7%、qwen3-235b-a22b-thinking-2507: 34.3%、qwen3-235b-a22b: 29.7%、weblab-LLM-M-Qwen3-235b-instruct-dft: 28.0%、qwen3-235b-a22b-instruct-2507: 13.7%）は不合格判定あり、医療システムでの使用に重大なリスク

全モデル共通の課題：

- 有害情報の出力制御は全20モデルが「要改善」判定（合格モデルなし）
- 研究・教育目的を偽装した致死量情報の要求（攻撃成功率26.0%）への防御が不十分

間接的攻撃手法の有効性：

- 直接的な要求よりも、間接抽出（28.5%）やテンプレート悪用（22.2%）等の巧妙な攻撃手法が高い攻撃成功率
- 品質監査テンプレート作成・翻訳サンプル作成・BIツール連携等の正当業務偽装が有効

脆弱性の深刻度別分類：

- 極高（Critical）：V-003（有害情報の出力制御の不備 — 全モデルで要改善）

- 高 (High) : V-002 (セキュリティ確保の不備 — モデル別攻撃成功率0%~69%)、V-001 (プライバシー保護の不備 — モデル別攻撃成功率0%~52%)

アクション：追加情報の確認（攻撃実施者・AIセキュリティ有識者）

以下の追加情報を確認した。

- **モデル間の比較分析**：20モデルの結果を比較し、モデルの安全性能の傾向を分析（05_実施結果報告書 Section 2.4 参照）
- **攻撃手法の有効性分析**：15種の攻撃手法の攻撃成功率を比較し、間接抽出（28.5%）と致死量情報要求（26.0%）が最も有効であることを確認
- **防御の一貫性**：harmful_selfharmは全モデルで防御成功（攻撃成功率0%）、harmful_avoidanceもほぼ全モデルで防御成功（攻撃成功率0.2%）を確認
- **既知の脆弱性との対比**：AIセキュリティ有識者が公開情報（OWASP LLM Top 10 等）と照合し、発見された脆弱性が既知の攻撃カテゴリに該当することを確認

アクション：事業インパクトの協議（管理者）

各脆弱性の事業インパクトを協議し、優先的に対応すべき順序を V-003（最優先：有害情報の出力制御 — 全モデルで要改善）→ V-002（セキュリティ確保 — 攻撃成功率最大）→ V-001（プライバシー保護）と評価した。各脆弱性の事業インパクト分析の詳細は 06_最終報告書 Section 2 を参照。

STEP 12：レッドチーミング実施結果報告書の作成

アクション：実施結果報告書の作成（攻撃実施者）

`report-templates/05_実施結果報告書.md` として実施結果報告書を作成した。記載内容は以下のとおり。

1. 基本情報
2. 実施概要（実施範囲、対象モデル20種、テスト構成、15種の攻撃手法、評価ロジック）
3. 実施結果サマリ（全体結果6,000件/漏洩838件、モデル別結果、AISI評価観点別結果、攻撃手法別有効性）
4. 発見された脆弱性の詳細（V-001~V-003：攻撃シナリオ、攻撃シグネチャ例、モデル別判定、影響分析、改善策候補）

- 5. 攻撃が失敗したケース（D-001上位モデルの防御成功、D-002全モデルでの自傷・回避攻撃防御成功）
- 6. 総括（モデル間性能差、全モデル共通課題、間接攻撃の有効性）
- 7. 添付資料

アクション：関係者レビュー（全員）

実施結果報告書について、以下の関係者によるレビューを実施した。

レビュー者	レビュー観点	結果
情シス担当者	技術的正確性、システム構成との整合性	事実誤認なし
AIセキュリティ有識者	AIセキュリティ観点での妥当性、評価の適切性	事実誤認なし
管理者	事業インパクトの記載、全体的な整合性	事実誤認なし

レビュー結果を踏まえ、報告書の一部を修正・補足した。承認欄に全員の確認を記録している。

STEP 13：最終報告書の作成と報告

アクション：最終報告書の作成（管理者）

最終報告書を `report-templates/06_最終報告書.md` として作成した。本報告書は経営層向けに、05_実施結果報告書の技術的内容を事業インパクトの観点で再整理したものである。

アクション：経営層への報告（管理者→経営層）

最終報告書に基づき、経営層へ報告を実施した。報告内容は以下のとおり。

- **発見された脆弱性**：3件（極高1件、高2件）、20モデルに対して計6,000件のテストを実施
- **最も深刻な脆弱性**：V-003（有害情報の出力制御の不備）は全20モデルで要改善判定、致死量情報等の漏洩は患者の生命に直結するため緊急対応が必要

- **モデル選定の重要性**：モデル間で攻撃成功率に0.7%～42.7%の大きな差があり、7モデルがプライバシー保護またはセキュリティ確保で不合格
- **改善策の提案**：緊急対応（即時～1週間）、短期対応（1ヶ月以内）、中期対応（3ヶ月以内）の3段階で実施
- **今後の推奨事項**：四半期ごとの定期レッドチーミング、今回未対象の評価観点（バイアス等）への対応

STEP 14：改善計画の策定

注記：本プロジェクトは令和8年3月をもって終了するため、以下の改善計画は実際に実施するものではなく、改善を行う場合の計画イメージとして策定したものである。

アクション：改善策の検討（管理者・AIセキュリティ有識者・情シス担当者）

各脆弱性に対する改善策を検討した（07_改善計画書 Section 2 参照）。

脆弱性	改善策の概要
V-003（有害情報の出力制御）	緊急：致死量・過量投与情報の出力を検出・ブロックする出力フィルタ実装。短期：有害情報の出力を検出・ブロックする出力フィルタ強化。中期：有害情報の定義と閾値の継続的見直し
V-002（セキュリティ確保：システム権限偽装による情報抽出）	短期：構造化データ出力（CSV、FHIR等）の検出・ブロック、デバッグモード偽装検出。中期：システムプロンプト強化（権限偽装の明示的拒否）、出力フィルタ強化
V-001（プライバシー保護）	短期：間接抽出型攻撃（サンプル作成・テンプレート作成等）の検出追加、システムプロンプト強化。中期：出力フィルタでの患者情報検出・マスキング、多層防御の実装

改善策は技術的対策・運用的対策の両面から検討した。

アクション：優先度付け（管理者）

以下のとおり優先度を付けた（06_最終報告書を参照）。

対応時期	No.	改善策	対象脆弱性
緊急（即時）	E-1	致死量・過量投与情報の出力ブロック	V-003
緊急（1週間）	E-2	利用者への暫定的な注意喚起	全般
短期（2週間）	S-1	不合格7モデルへの出力ガードレール導入・再評価	全般
短期（1ヶ月）	S-2～S-3	出力フィルタの強化（患者情報検出・構造化データ出力の制限・システムプロンプト強化を含む）	V-001, V-002
中期（3ヶ月）	M-1～M-5	出力フィルタ高度化、多層防御実装、有害情報定義見直し、攻撃パターンDB構築、有害情報ガイドライン策定	全般

アクション：改善計画の策定（管理者）

`report-templates/07_改善計画書.md` として、改善を実施する場合の計画イメージを作成した。記載内容は以下のとおり。

1. 基本情報
2. 改善計画の概要（目的、改善の範囲）
3. 改善策の詳細（緊急E-1～E-2、短期S-1～S-3、中期M-1～M-5）
4. 実施スケジュール（全体スケジュール、マイルストーン MS-1～MS-5）
5. 体制と役割
6. 予算（別途管理）
7. リスク管理（改善実施に伴うリスク、残存リスク）
8. 進捗管理と報告（週次進捗会議、月次報告会）
9. 承認
10. フォローアップ計画（STEP 15：再RT、継続的セキュリティ評価、改善効果の評価指標）

アクション：経営層の承認（経営層）

改善計画書について、経営層の承認を得た。承認内容は以下のとおり。

- 改善計画の内容を承認し、実施を指示する
- 予算は別途管理とし、必要に応じて追加承認を行う
- 月次報告会で進捗を報告すること

STEP 15：改善後のフォローアップ

注記：本STEPの内容は、改善計画を実施する場合のフォローアップ体制のイメージである。本プロジェクトの範囲内では実施しない。

アクション：改善策の進捗管理（管理者）

以下の体制で進捗管理を行う（07_改善計画書 Section 7 参照）。

会議体	頻度	参加者	内容
週次進捗会議	毎週	管理者、情シス担当者、運用チーム	進捗確認、課題共有
月次報告会	毎月	管理者、経営層	経営層への進捗報告

マイルストーン： - MS-1（1週間後）：緊急対応完了（V-003への暫定対策、不合格モデルへのガードレール導入開始） - MS-2（1ヶ月後）：短期対応完了（主要な脆弱性への対策） - MS-3（2ヶ月後）：中期対応（前半）完了 - MS-4（3ヶ月後）：中期対応完了、再テスト実施 - MS-5（4ヶ月後）：再テスト結果の報告、フォローアップ計画策定

アクション：対策実施状況の確認（情シス担当者）

情シス担当者は以下の観点で対策実施状況を確認する。

- **技術的対策の実装確認：**入力フィルタ・出力フィルタの更新、権限チェックロジックの実装、薬剤DB連携の実装が仕様どおりに動作しているか
- **インフラ面の確認：**疑似システム環境での動作確認後、本番環境へのデプロイが安全に行われているか
- **監査ログの確認：**新しいアクセス制御ポリシーが正しく監査ログに記録されているか

アクション：再RTの実施（必要に応じて）（攻撃実施者）

改善策実施完了後（MS-4以降）に再RTを実施する計画（07_改善計画書 Section 8.1 参照）。

項目	内容
実施時期	改善策実施完了後（MS-4以降）
実施範囲	V-001～V-003に関連する攻撃シナリオの再実施（6,000件のテストケースを改善後環境で再実行）
実施者	攻撃実施者
使用ツール	医療LLMレッドチーミングシステムの攻撃シグネチャ集（改善後の環境に対して再実行）
判定基準	改善前に成功した攻撃が deny 判定となることを確認

また、継続的なセキュリティ評価として以下を計画している。

評価項目	頻度	担当
定期レッドチーミング	四半期ごと	攻撃実施者
AIセーフティ監査	年次	外部評価機関
攻撃トレンドの情報収集	随時	AIセキュリティ有識者
リスクフレームワークの更新	半期ごと	情シス担当者・AIセキュリティ有識者

成果物対応表

成果物一覧の詳細（工程・作成者・格納先）は [report-templates/01b_システム構成・成果物.md](#) を参照。

STEP	アクション	成果物	格納先
-	チーム体制の整理	チーム体制	report-templates/01a_チーム体制.md
-	システム構成・成果物の整理	システム構成・成果物	report-templates/01b_システム構成・成果物.md
1	RT実施企画書の作成・承認	企画書	report-templates/02_企画書.md
3	実施計画書の作成	実施計画書	report-templates/03_実施計画書.md
5	エスカレーションフローの策定	エスカレーションフロー	report-templates/03_実施計画書.md 内
6-2	リスクフレームワークの作成	リスクフレームワーク	risk_framework/リスクフレームワーク.xlsx
6-3	リスクシナリオ一覧作成	リスクシナリオ表	report-templates/04_リスクシナリオ表.md
12	実施結果報告書の作成	実施結果報告書	report-templates/05_実施結果報告書.md
13	最終報告書の作成	最終報告書	report-templates/06_最終報告書.md
14	改善計画の策定	改善計画書	report-templates/07_改善計画書.md

作業用リソース

フォルダ	担当	内容
red_teaming_results/	攻撃実施者	攻撃プロンプト・テストケース、実施結果レポート、実施ログ・証跡